
TABLA DE CONTENIDOS

1. Resumen Ejecutivo
2. Metodología de Investigación
3. Hallazgos del Análisis Forense
4. Investigación de Persistencia y Código Malicioso
5. Acciones de Remediación Ejecutadas
6. Recomendaciones de Fortalecimiento
7. Cronología del Incidente
8. Conclusiones

1. RESUMEN EJECUTIVO

El presente documento detalla la investigación realizada tras la detección de una intrusión en un servidor de producción. El ataque se llevó a cabo mediante la explotación de credenciales comprometidas del usuario root a través del servicio SSH.

Impacto del incidente: Acceso no autorizado con privilegios elevados, intentos de modificación de configuración del sistema y posible intento de persistencia.

Tiempo de detección: Posterior al evento, mediante revisión de logs del sistema.

Nivel de severidad: CRÍTICO

Estado: Incidente contenido y sistema asegurado.

2. METODOLOGÍA DE INVESTIGACIÓN

Para este análisis se siguieron las mejores prácticas de respuesta a incidentes de seguridad, basadas en el framework NIST SP 800-61 y guías de SANS para análisis forense digital.

Fases ejecutadas:

- Identificación: Detección inicial del compromiso
- Contención: Aislamiento del servidor afectado
- Erradicación: Eliminación de posibles backdoors

- Recuperación: Restauración de servicios con configuración segura
- Lecciones aprendidas: Documentación y mejora de controles

Herramientas utilizadas en el análisis:

- journalctl: Análisis de registros del sistema
- .bash_history: Reconstrucción de actividades del atacante
- last: Detección de sesiones e reinicios
- chkrootkit: Búsqueda de rootkits
- Manual inspection: Análisis directo de archivos de configuración

3. HALLAZGOS DEL ANÁLISIS FORENSE

3.1 Vector de Ataque Identificado

El punto de entrada fue el servicio SSH (puerto TCP 22), que se encontraba expuesto y con autenticación por contraseña habilitada. El atacante obtuvo acceso utilizando credenciales válidas del usuario root.

Dirección de origen: 192.168.0.13
Servicio explotado: SSH - puerto 22
Tipo de explotación: Credenciales comprometidas
Fecha estimada del incidente: Octubre 2024

3.2 Evidencias de la Intrusión

La evidencia primaria proviene de los logs del sistema, consultados mediante journalctl. Se confirmaron las siguientes actividades:

- Inicio de sesión SSH exitoso del usuario root desde IP no autorizada
- Comandos ejecutados en el sistema posterior al acceso
- Reinicios no programados del servidor

3.3 Actividades Registradas del Intruso

Mediante el análisis del historial de comandos (.bash_history) del usuario root, se reconstruyó la secuencia de acciones del atacante:

- Intento de modificación de la configuración sudo mediante el comando visudo, lo que sugiere un intento de crear o modificar privilegios de usuarios adicionales
- Intento de detener servicios del sistema, específicamente speech-dispatcher, posiblemente para ocultar actividad o liberar recursos
- Navegación por directorios sensibles del sistema

3.4 Análisis de Disponibilidad del Sistema

El comando last permitió identificar sesiones de usuario y reinicios del sistema. Se observaron caídas no programadas en las fechas cercanas al incidente, lo que podría indicar:

- Reinicios forzados por el atacante
- Inestabilidad del sistema provocada por las acciones maliciosas
- Intentos de ocultar evidencia mediante reinicio

4. INVESTIGACIÓN DE PERSISTENCIA Y CÓDIGO MALICIOSO

4.1 Búsqueda de Rootkits

Se ejecutó la herramienta chkrootkit para detectar la presencia de rootkits conocidos. Los resultados se detallan a continuación:

Ficheros con marcas de tiempo sospechosas:

- Se analizó el directorio /usr/lib/libreoffice/share/registry/ debido a incoherencias en las marcas temporales de sus archivos
- Tras inspección manual, se confirmó que los archivos pertenecen a la instalación legítima de LibreOffice y no representan amenaza

Falsos positivos detectados:

- Alerta relacionada con el proceso NetworkManager (PID 530), inicialmente marcado como posible sniffer
- Análisis posterior confirmó que se trataba del proceso legítimo de gestión de red del sistema

Conclusión: No se halló malware persistente ni rootkits activos en el sistema.

4.2 Análisis de Usuarios y Grupos

Se realizó una auditoría completa de cuentas del sistema:

- Revisión del archivo /etc/passwd para identificar cuentas no autorizadas
- Verificación del archivo /etc/shadow para detectar usuarios con contraseñas débiles
- Análisis del archivo /etc/sudoers para identificar privilegios elevados no autorizados

Resultado: No se encontraron cuentas backdoor ni modificaciones no autorizadas en los privilegios de sudo.

5. ACCIONES DE REMEDIACIÓN EJECUTADAS

5.1 Endurecimiento del Servicio SSH

Se aplicaron las siguientes modificaciones en /etc/ssh/sshd_config:

- Establecimiento de PermitRootLogin no para bloquear el acceso remoto del usuario root
- Verificación de que la configuración nueva fue cargada correctamente
- Reinicio del servicio SSH para aplicar los cambios

Validación: El acceso SSH como root desde el exterior es ahora rechazado.

5.2 Rotación de Credenciales

- Cambio inmediato de la contraseña del usuario root
- Notificación a todos los usuarios con privilegios elevados para cambiar sus credenciales
- Revisión de historial de contraseñas para evitar reutilización

5.3 Auditoría de Permisos y Configuración

- Verificación del archivo /etc/sudoers: Confirmado que no existen entradas maliciosas
- Revisión de /etc/passwd: No se detectaron usuarios creados por el atacante
- Análisis de directorios temporales: No se hallaron scripts o binarios sospechosos

5.4 Actualización del Sistema

- Aplicación de todas las actualizaciones de seguridad pendientes
- Revisión de los paquetes instalados para detectar software no autorizado

6. RECOMENDACIONES DE FORTALECIMIENTO

A continuación se presentan las recomendaciones ordenadas por prioridad:

PRIORIDAD ALTA

1. Autenticación por Claves SSH

- Implementar autenticación basada en llaves criptográficas para SSH
- Deshabilitar completamente la autenticación por contraseña
- Configurar el directorio .ssh con permisos restrictivos (700 para el directorio, 600 para archivos)

2. Sistema de Prevención de Ataques de Fuerza Bruta

- Instalar y configurar Fail2Ban para monitorear logs de autenticación
- Establecer regla para SSH: banear IP tras 5 intentos fallidos en 10 minutos
- Configurar tiempo de bloqueo de 1 hora por defecto

3. Monitoreo de Accesos Privilegiados

- Configurar alertas para logins exitosos de usuarios con sudo
- Implementar logging centralizado de eventos de autenticación
- Revisión semanal de logs de acceso SSH

PRIORIDAD MEDIA

4. Segmentación de Red

- Restringir el acceso al puerto SSH solo desde IPs autorizadas
- Implementar reglas de firewall que limiten el rango de IPs permitidas
- Considerar el uso de una bastión host para acceso remoto

5. Cambio de Puerto SSH (Defensa en Profundidad)

- Cambiar el puerto SSH del estándar 22 a un puerto no convencional
- Notar que esto no reemplaza las medidas de seguridad, solo reduce ruido

PRIORIDAD BAJA

6. Implementación de IDS/IPS

- Evaluar la instalación de Snort o Suricata para detección de intrusión
- Configurar reglas específicas para detección de escaneo y fuerza bruta

7. Sistema de Gestión de Configuraciones

- Implementar herramienta de gestión de configuración (Ansible, Puppet)
- Mantener baseline de configuración segura verificable

8. Auditoría de Seguridad Periódica

- Programar auditorías trimestrales de seguridad
- Realizar pruebas de penetración anuales

7. CRONOLOGÍA DEL INCIDENTE

| Fase | Actividad | Tiempo Estimado |

|-----|-----|-----|

1	Acceso inicial del atacante vía SSH	D-8 Octubre 2024
2	Ejecución de comandos en el sistema	Minutos posteriores
3	Intento de modificación de privilegios	Minutos posteriores
4	Reinicios no planificados del sistema	Horas posteriores
5	Detección del incidente por el equipo	Posterior
6	Aislamiento y contención	Inmediato tras detección
7	Análisis forense completo	Días posteriores
8	Implementación de medidas correctivas	Semanas posteriores
9	Implementación de recomendaciones	En progreso

8. CONCLUSIONES

1. El incidente se originó por una configuración insegura del servicio SSH que permitía acceso root con contraseña. Este vector de ataque es ampliamente conocido y altamente explotado.

2. A pesar del acceso con privilegios elevados, el atacante no logró establecer persistencia ni comprometer completamente el sistema, lo que indica que el tiempo de residencia fue limitado.

3. Las medidas correctivas aplicadas han mitigado significativamente el riesgo de reocurrencia por el mismo vector, pero se requieren acciones adicionales para fortalecer la postura de seguridad general.

4. La priorización más crítica es la implementación de autenticación por claves SSH y la desactivación de acceso root remoto, ya que estas medidas eliminarían el vector de ataque principal.

5. Se recomienda establecer un programa continuo de monitoreo y auditoría de seguridad para detectar futuras anomalías de forma proactiva.